Penetration Testing Report

Target Information:

- **Target IP:** 154.57.164.73
- **Port:** 31081
- **Assessment Type:** Web Application Penetration Testing
- **Testing Methodology:** Black Box Testing

1. **Executive Summary:**

   During the penetration testing engagement, multiple critical vulnerabilities were identified in the target system. These vulnerabilities allowed unauthorized access to administrative functionality and exposed the application to potential **Remote Code Execution (RCE)** risks.

   The most critical issue was the presence of **default credentials in the source code**, which led to full authentication bypass and unauthorized admin access.

2. **Methodology:**

   The following steps were performed:

2.1 Directory Enumeration

- Tool Used: gobuster
- Mode: Directory brute force (dir)
- Wordlist: SecLists

Findings:

Discovered accessible endpoints:

- /wordpress
- /robots.txt

- /index.php

```
┌──(root㉿kali)-[/home/mehdi]
└─# gobuster dir -u http://154.57.164.73:31081  -w /usr/share/seclists/Discovery/Web-Content/common.txt
═══════════════════════════════════════════════════════════════
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
═══════════════════════════════════════════════════════════════
[+] Url:                     http://154.57.164.73:31081
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Timeout:                 10s
═══════════════════════════════════════════════════════════════
Starting gobuster in directory enumeration mode
═══════════════════════════════════════════════════════════════
/.hta                (Status: 403) [Size: 281]
/.htpasswd           (Status: 403) [Size: 281]
/.htaccess           (Status: 403) [Size: 281]
/index.php           (Status: 200) [Size: 990]
/robots.txt          (Status: 200) [Size: 45]
/server-status       (Status: 403) [Size: 281]
/wordpress           (Status: 301) [Size: 327] [--> http://154.57.164.73:31081/wordpress/]
Progress: 4750 / 4750 (100.00%)
═══════════════════════════════════════════════════════════════
Finished
═══════════════════════════════════════════════════════════════

┌──(root㉿kali)-[/home/mehdi]
└─#
```

3. Findings & Vulnerabilities

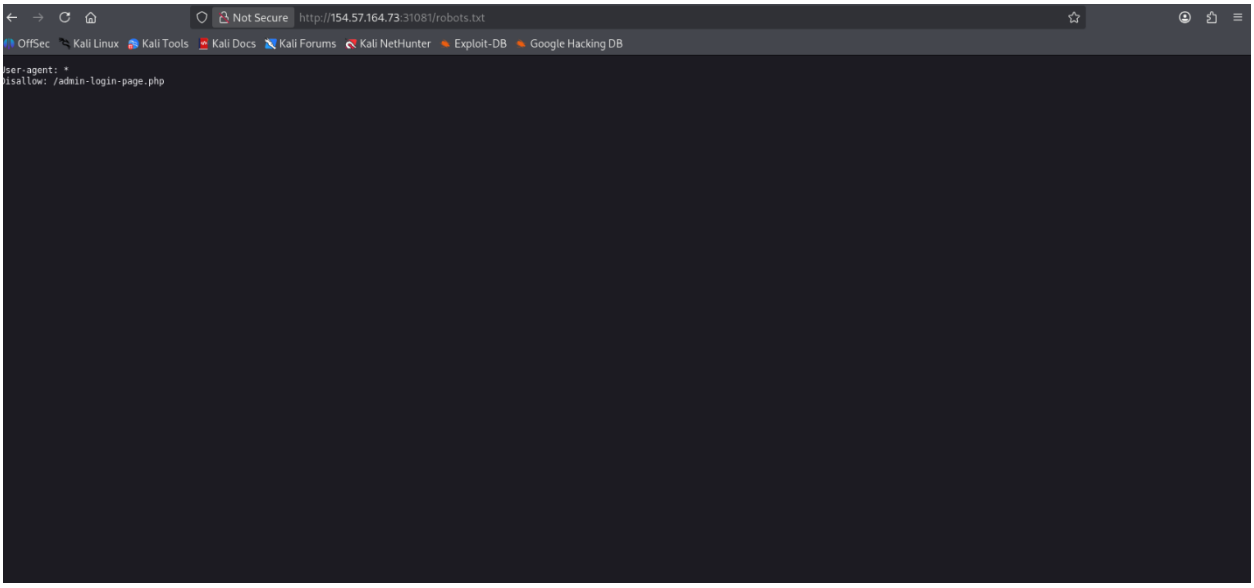
3.1 Exposure of Sensitive Endpoints via robots.txt

- **URL:** /robots.txt
- **Severity:** Medium

Description:

The robots.txt file exposed a sensitive endpoint: /admin-page-login.php

Impact:Attackers can discover hidden or sensitive paths easily.



3.2 Default Credentials Exposure in Source Code

- **URL:** /admin-page-login.php
- **Severity:** Critical

Description:

Upon visiting the login page and inspecting the source code, default credentials were found hardcoded.

Vulnerability Type:

- Hardcoded Credentials
- Improper Security Configuration

Impact:

- Unauthorized access to admin panel
- Full control over application (depending on privileges)

```
    }
</style>

<body>
                <form name='login' autocomplete='off' class='form' action='' method='post'>
            <div class='control'>
                <h1>
                    Admin Panel
                </h1>
            </div>
            <div class="container">
                <label for="username"><b>Username</b></label>
                <input name='username' placeholder='Username' type='text'>

                <label for="password"><b>Password</b></label>
                <input name='password' placeholder='Password' type='password'>

                <!-- TODO: remove test credentials admin:password123 -->

                <button type="submit" formmethod='post'>Login</button>
            </div>
        </form>
    </body>
```

3.3 WordPress Application in Testing Mode (Potential RCE Risk)

- **URL:** /wordpress
- **Severity:** High

Description:

The WordPress instance was found in a testing or incomplete configuration state. Such environments often contain:

- Debug modes enabled

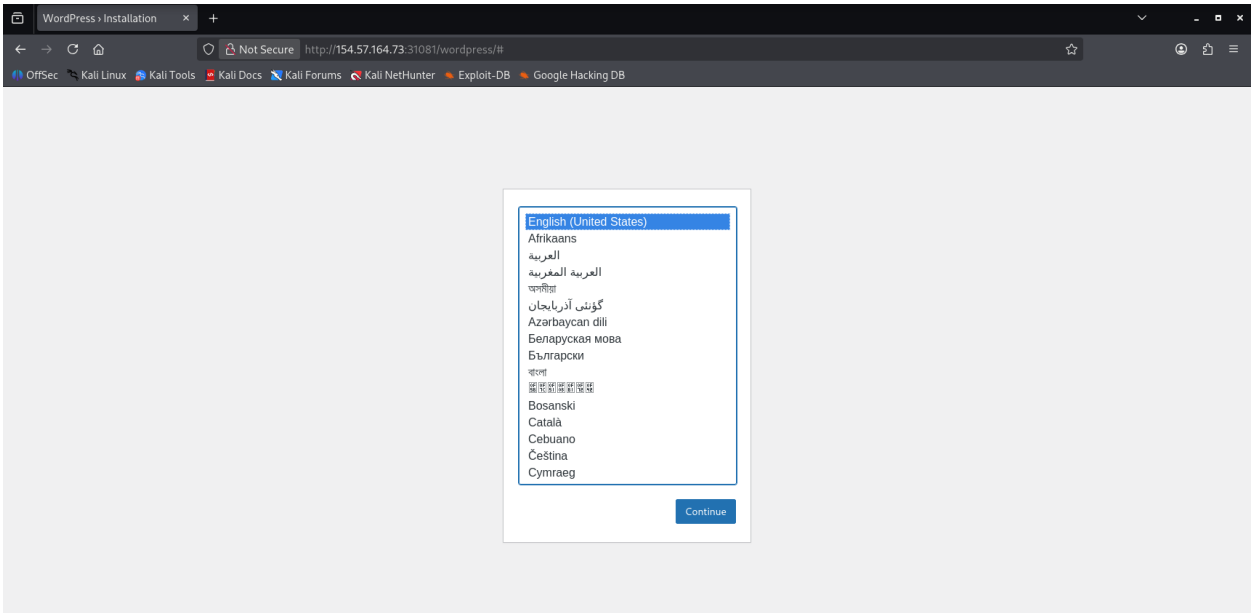
- Vulnerable plugins/themes
- Misconfigurations

Potential Risk:

- Remote Code Execution (RCE)
- Plugin exploitation
- File upload vulnerabilities

Impact:

An attacker could exploit misconfigurations to gain shell access.



4. Risk Summary

Vulnerability	Severity
Default Credentials	Critical
WordPress Misconfiguration	High
robots.txt Information Disclosure	Medium

5. Recommendations

Immediate Actions:

- Remove hardcoded credentials from source code
- Change all default credentials immediately
- Restrict access to admin panel (IP whitelist / authentication hardening)

WordPress Security:

- Disable debug/testing mode
- Update all plugins/themes
- Remove unused components

robots.txt:

- Do not include sensitive endpoints
- Use proper access control instead

6. Conclusion

The application suffers from critical security misconfigurations, primarily due to poor credential management and exposure of sensitive endpoints. Immediate remediation is required to prevent unauthorized access and potential full system compromise.